

User Email Security & Threat Intelligence

Comprehensive 100+ Page Topic-Based RAG Knowledge Base

Purpose

This reference is written for a user-facing email security assistant. It explains the major concepts used by an AI-powered email threat detection platform from basic to advanced level. It is organized by topics rather than question lists so that RAG retrieval can return coherent explanatory passages. Each topic contains practical examples and clear distinctions between evidence, risk signals, and conclusions.

Important interpretation rule: security indicators are signals, not automatic proof. For example, a VPN, TOR exit node, foreign IP, SPF failure, or high reputation score should be interpreted with the rest of the email context.

Core platform concepts covered: Gmail, email headers, SPF, DKIM, DMARC, Reply-To, Return-Path, Message-ID, Received headers, IP intelligence, geolocation, VPN, proxy, TOR, ASN, ISP, URLs, domains, DNS, phishing, BEC, malware, attachments, AI risk scoring, false positives, incident response, account recovery, and safe user behavior.

1. Email Security Fundamentals

Concept

Email security protects messages, accounts, identities, links, attachments, and information exchanged through email. A secure email workflow does not depend on one control.

It combines authentication, filtering, threat intelligence, malware analysis, user awareness, access controls, monitoring, and incident response. The goal is to reduce the chance that a malicious message causes credential theft, financial loss, malware infection, data exposure, or account compromise.

Practical example

A message asking an employee to urgently change a vendor bank account should not be trusted merely because the sender name looks familiar. The user should verify the request through a trusted channel before making the change.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

2. Phishing

Concept

Phishing is a social-engineering attack in which an attacker tries to make a victim perform an unsafe action.

The action may be entering credentials, opening a malicious attachment, clicking a fraudulent URL, approving an authentication request, transferring money, or revealing confidential information. Phishing can be generic or highly targeted.

Practical example

Example: an email claims that a Microsoft account will be disabled today and provides a sign-in link. The message uses urgency to reduce the time available for verification.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

3. Spear Phishing

Concept

Spear phishing is targeted phishing.

Instead of sending the same message to thousands of recipients, an attacker uses information about a particular person, department, company, project, or supplier. Personalization can make the message appear more credible, but the underlying goal remains deception.

Practical example

Example: an attacker knows an employee's manager and project name and sends a request that appears to come from the manager.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

4. Whaling

Concept

Whaling is a form of targeted phishing directed at high-value individuals such as executives or people with financial authority.

The attacker may attempt to initiate payments, obtain sensitive information, or compromise privileged accounts.

Practical example

Example: a fake message from a chief financial officer asks an employee to make an urgent transfer before a meeting.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

5. Business Email Compromise

Concept

Business Email Compromise, or BEC, is a fraud pattern involving impersonated or compromised business email identities.

Common objectives include fraudulent payments, payroll diversion, invoice manipulation, gift-card scams, sensitive-data theft, and access to business processes. BEC may not contain malware at all; the social engineering itself can cause the loss.

Practical example

Example: a real supplier conversation is compromised and the attacker inserts new bank details before an invoice is paid.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

6. Email Spoofing

Concept

Spoofing means manipulating identity information so a message appears to originate from another sender or domain.

Email authentication mechanisms such as SPF, DKIM, and DMARC help receiving systems evaluate some forms of spoofing, but they do not make malicious email impossible.

Practical example

Example: a forged message claims to be from finance. Authentication results can provide evidence that the visible sender identity was not authorized in the expected way.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

7. Display Name Impersonation

Concept

A display name is the human-readable sender label shown by an email application.

It is not the same thing as the actual sending address. Attackers can set a display name to a trusted person's name, so users should inspect the underlying address and context.

Practical example

Example: the display name says 'IT Support' while the actual address belongs to an unrelated domain.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

8. Look-Alike Domains

Concept

A look-alike domain is designed to resemble a legitimate domain while being different from it.

Attackers may use spelling changes, additional words, hyphens, alternate top-level domains, or visually similar characters. Domain inspection should focus on the registrable domain rather than the most familiar-looking part of the URL.

Practical example

Example: a legitimate company uses example.com while an attacker registers example-security.com and presents it as an official security portal.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

9. Reply-To

Concept

The Reply-To header can specify where replies should be delivered.

It may legitimately differ from the visible From address, but an unexpected mismatch can be useful evidence in phishing or impersonation analysis. A mismatch is a signal, not proof of maliciousness.

Practical example

Example: a message appears to come from a supplier but replies are directed to a different unrelated domain.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

10. Return-Path

Concept

Return-Path is associated with the address used for delivery-related bounce processing.

It can provide useful technical context during email analysis. It should not be interpreted as a simple 'real sender' field because modern email delivery involves multiple identities and services.

Practical example

Example: the visible From address belongs to a business, while the envelope-related address belongs to a different mail system. This difference may deserve review.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

11. Message-ID

Concept

Message-ID is an identifier associated with an email message.

It can help systems correlate messages, identify duplicates, and support forensic analysis. It is useful as evidence but should not be treated as a cryptographic identity of the sender.

Practical example

Example: the application stores Gmail's message ID to ensure the same dangerous email does not trigger multiple warning notifications.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

12. Received Headers

Concept

Received headers describe mail-server hops recorded as a message moves through mail infrastructure.

They can help investigators understand routing and identify relevant infrastructure. Header interpretation must account for trusted mail gateways, forwarding services, and organizational architecture.

Practical example

Example: a message may pass through a cloud mail security gateway before reaching Gmail. The earliest useful hop may not be the same as the server the user's mailbox directly connected to.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

13. Authentication-Results

Concept

Authentication-Results is a header where a receiving mail system can record checks such as SPF, DKIM, and DMARC.

It is valuable because it records the receiving system's evaluation. The results still need context because authentication is not equivalent to intent or trust.

Practical example

Example: DMARC passes but the message contains a suspicious request for credentials. The authentication result does not override the behavioral evidence.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

14. SPF

Concept

Sender Policy Framework, or SPF, allows a domain owner to publish which mail servers are authorized to send mail for that domain.

A receiving system can compare the sending server with the published policy. SPF primarily addresses authorization of the sending infrastructure and is not a complete phishing detector.

Practical example

Example: if an email claims to use a domain whose SPF policy does not authorize the observed sending server, the receiver may record an SPF failure.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

15. SPF Pass

Concept

An SPF pass means the evaluated sending server was authorized under the relevant SPF policy for the identity being checked.

It is a positive technical signal but does not mean the email is safe. A compromised account or authorized third-party sender can still send malicious content.

Practical example

Example: an attacker compromises a legitimate mailbox hosted by an authorized provider. SPF can still pass because the infrastructure is authorized.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

16. SPF Fail

Concept

An SPF failure means the sending server did not satisfy the relevant SPF authorization policy for the identity evaluated.

It can be a strong warning signal, especially when combined with other anomalies, but forwarding and complex mail paths can affect SPF results.

Practical example

Example: a message claims to originate from a company domain but arrives from an unauthorized server and fails SPF.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

17. DKIM

Concept

DomainKeys Identified Mail, or DKIM, adds a cryptographic signature to email.

A receiving system can retrieve the public key published by the signing domain and verify the signature. DKIM helps establish that the message was signed by a domain and that signed content was not altered in transit.

Practical example

Example: a legitimate organization signs outbound mail with DKIM. The receiving system verifies the signature against the organization's published key.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

18. DKIM Pass

Concept

A DKIM pass indicates that the receiving system successfully verified the relevant signature.

This supports message integrity and domain association for the signed content. It does not prove that the human sender intended the message or that the request is safe.

Practical example

Example: a compromised corporate account can generate correctly signed messages because the attacker is using the organization's legitimate mail system.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

19. DKIM Fail

Concept

A DKIM failure means the relevant signature could not be successfully verified.

Possible causes include modification, configuration problems, key issues, or a message path that affected signed content. It is a useful signal but should be interpreted with SPF and DMARC.

Practical example

Example: a message fails DKIM and also contains a suspicious login link. The combined evidence is more concerning than either signal alone.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

20. DMARC

Concept

Domain-based Message Authentication, Reporting, and Conformance, or DMARC, builds on SPF and DKIM and allows a domain owner to publish a policy.

DMARC also considers alignment between the visible From domain and authenticated identities. This helps receiving systems handle some forms of domain impersonation.

Practical example

Example: a domain can publish a DMARC policy that asks receivers to reject or quarantine messages that fail the required checks.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

21. DMARC Pass

Concept

A DMARC pass means the message satisfied the relevant DMARC authentication and alignment requirements under the receiving system's evaluation.

It reduces certain spoofing risks, but it does not mean the message is harmless. Compromised legitimate accounts and malicious authorized senders remain possible.

Practical example

Example: a phishing message sent from a compromised legitimate mailbox can pass DMARC while still trying to steal credentials.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

22. DMARC Fail

Concept

A DMARC failure indicates that the message did not satisfy the domain's DMARC requirements.

It can be an important impersonation signal. However, forwarding and configuration issues can sometimes contribute to failures, so a failure should be considered together with the mail path and other evidence.

Practical example

Example: a message visibly claiming to be from a protected domain fails both alignment and authentication checks.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

23. SPF vs DKIM vs DMARC

Concept

SPF answers an infrastructure authorization question: is this sending server authorized for the evaluated identity? DKIM answers a signature question: can the receiver verify the domain's cryptographic signature?

DMARC adds policy and alignment around the visible From identity using SPF and/or DKIM. These controls complement each other.

Practical example

Example: SPF may fail while DKIM passes through a legitimate mail service. DMARC determines whether the passing authentication is aligned with the visible From domain under the domain's policy.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

24. Gmail Integration

Concept

Gmail integration allows an application to access email data through Google's authorized APIs.

A user must grant the requested permissions through OAuth. A production system should request only the permissions needed for its functions, store tokens securely, and never expose OAuth secrets to the frontend.

Practical example

Example: the user signs in with Google, grants the requested Gmail permission, and the backend uses the resulting authorization to analyze newly received messages.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

25. Gmail OAuth

Concept

OAuth is an authorization mechanism that lets a user grant an application access to selected resources without giving the application the user's Google password.

The authorization flow should use Google's supported mechanisms and secure redirect URIs. Tokens are sensitive credentials and must be protected.

Practical example

Example: the website sends the user to Google's consent screen; after approval, Google redirects to the backend callback and the backend stores the resulting authorization securely.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

26. Gmail Monitoring

Concept

Automatic monitoring allows the application to react to new messages after the user explicitly enables monitoring.

A production architecture can use Gmail watch notifications with Google Pub/Sub rather than repeatedly polling the mailbox. Monitoring should be scoped to the authenticated user and stopped when the user disables it.

Practical example

Example: a new Gmail notification arrives, the backend fetches the corresponding message, analyzes it, stores evidence, and sends a warning only when the risk policy requires it.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

27. Inbox vs Spam

Concept

Suspicious mail can appear in different Gmail labels or folders.

A security application should define clearly which locations it monitors and avoid assuming that only the Inbox matters. Spam messages may still be useful for threat analysis and user education.

Practical example

Example: a phishing message delivered to Spam can be analyzed for threat intelligence without automatically moving it into the Inbox.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

28. SMTP

Concept

Simple Mail Transfer Protocol, or SMTP, is a protocol used to send email.

In an alerting system, SMTP can be used by the backend to send a warning message to the authenticated user's configured notification address. SMTP is a sending mechanism, not an identity-verification system.

Practical example

Example: the threat engine marks a message as high risk and the backend sends a warning from the configured security mailbox to the user's notification address.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

29. IP Address

Concept

An IP address identifies a network endpoint used for communication.

Email systems commonly involve multiple servers, relays, security gateways, and cloud services. Therefore, an observed email IP should be interpreted as infrastructure evidence rather than automatically as the attacker's personal device.

Practical example

Example: the source IP belongs to a large cloud mail provider. That fact alone does not identify the individual who authored the message.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

30. IPv4 and IPv6

Concept

IPv4 and IPv6 are different Internet Protocol addressing systems.

Security tools may encounter either format. An application should normalize and validate addresses before querying threat-intelligence services and should not assume every address is globally routable.

Practical example

Example: an internal private IPv4 address should not be treated like a public Internet sender IP.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

31. Public vs Private IP

Concept

Private IP addresses are used inside local networks and are not globally routable in the same way as public addresses.

Public IP addresses can be observed across the Internet. Email forensic analysis generally gains more useful external infrastructure information from relevant public IPs.

Practical example

Example: 192.168.x.x is a private IPv4 range and does not identify a public mail server on the Internet.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

32. IP Geolocation

Concept

IP geolocation estimates the geographic area associated with an IP address using databases and network information.

It may return country, region, city, latitude/longitude estimates, timezone, or organization information depending on the provider. It is not GPS and should never be described as an exact physical location.

Practical example

Example: an IP may be geolocated to a city because a provider associates the address range with that city, while the actual person using the service is elsewhere.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

33. Geolocation: Person vs Server

Concept

This distinction is critical.

In email analysis, the IP available to the application may represent a mail server, relay, cloud service, VPN endpoint, proxy, or security gateway. Therefore the resulting location is usually best described as the approximate location of the observed network infrastructure, not the sender's exact physical location.

Practical example

Example: an email's IP geolocates to Frankfurt. The safe interpretation is 'the observed IP is associated with infrastructure in or around Frankfurt'; it is not 'the attacker is physically in Frankfurt.'

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

34. Geolocation Accuracy

Concept

IP geolocation accuracy varies by provider, address type, network ownership, and data freshness.

City-level results can be useful for context but can be wrong or approximate. Country-level results are generally safer to communicate when precise confidence is unavailable.

Practical example

Example: two databases may associate the same IP with different nearby cities. This is a reminder that geolocation is an estimate.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

35. Latitude and Longitude from IP

Concept

When an IP intelligence provider returns latitude and longitude, those coordinates usually represent an approximate location associated with the IP database record.

They should not be plotted or described as the exact location of a person.

Practical example

Example: a map marker for an IP can be labeled 'Approximate IP location' rather than 'Attacker location.'

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

36. ISP

Concept

Internet Service Provider information describes the organization associated with network connectivity or an IP allocation.

The ISP field can help distinguish residential, business, cloud, hosting, or specialized infrastructure, but the label is not proof of malicious activity.

Practical example

Example: an IP associated with a major cloud provider may indicate hosted infrastructure rather than a home connection.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

37. ASN

Concept

An Autonomous System Number identifies an autonomous system that announces IP prefixes on the Internet.

ASN information can help investigators group IP addresses by network operator or infrastructure owner.

Practical example

Example: several suspicious IPs may belong to the same ASN, providing a useful infrastructure correlation signal.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

38. VPN

Concept

A Virtual Private Network routes traffic through another network endpoint.

Security services may identify an IP as associated with VPN infrastructure. VPN use is not inherently malicious; people and organizations use VPNs for privacy, remote work, and legitimate security purposes.

Practical example

Example: a login or email-related IP is identified as a VPN endpoint. The correct conclusion is that the observed connection may be anonymized or routed through a VPN, not that the user is an attacker.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

39. Proxy

Concept

A proxy acts as an intermediary between a client and another service.

Proxy infrastructure can hide the original network source from the destination. Security providers may flag known proxy or relay addresses.

Practical example

Example: an email-related IP is associated with a proxy service. This increases uncertainty about the original source but does not prove malicious intent.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

40. TOR

Concept

Tor is a privacy-oriented network that routes traffic through multiple relays.

A service may identify an IP as a Tor exit node. A Tor indicator can be relevant to risk analysis because it makes attribution more difficult, but Tor use itself is not proof of malicious behavior.

Practical example

Example: an observed IP is a known Tor exit node. The system should explain that the traffic emerged from a Tor exit point and that the original source cannot be inferred from that IP alone.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

41. VPN vs Proxy vs TOR

Concept

VPNs, proxies, and Tor can all change the network endpoint visible to a destination, but they are different technologies and have different architectures.

A VPN commonly creates an encrypted tunnel to a provider endpoint; a proxy forwards traffic as an intermediary; Tor uses a multi-relay privacy network. Detection services may classify infrastructure differently.

Practical example

Example: 'VPN detected' and 'Tor detected' should be displayed as separate indicators rather than treating them as identical.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

42. IP Reputation

Concept

IP reputation is a risk signal based on historical observations, reported abuse, infrastructure characteristics, and provider-specific intelligence.

A high-risk reputation can support a threat decision but should not be treated as conclusive proof. Shared infrastructure can produce noisy reputation data.

Practical example

Example: an IP has a high abuse score, but the message is a legitimate automated notification. The application should consider the entire context.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

43. Fraud Score

Concept

A fraud score is a provider-specific numerical assessment of risk.

Different providers use different methods, so scores should be explained as provider signals rather than universal measurements. A score should not be presented as a probability unless the provider explicitly defines it that way.

Practical example

Example: a fraud score of 15/100 can be described as a low provider risk signal, but it does not guarantee the email is safe.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

44. Recent Abuse

Concept

Threat-intelligence services may report whether an IP has been associated with recent abuse.

Recency can make a signal more relevant, but absence of recent abuse does not prove safety. Attack infrastructure can be new, private, or simply not observed by the provider.

Practical example

Example: an IP has no recent abuse reports but hosts a newly created phishing page. The absence of reports does not eliminate risk.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

45. IPQualityScore

Concept

IPQualityScore can provide IP intelligence and related risk signals such as proxy/VPN/Tor indicators, fraud scoring, organization information, and approximate geolocation depending on the API and plan.

In an email threat platform, the result should be used as one layer of threat intelligence rather than the sole classifier.

Practical example

Example: the backend extracts a relevant public IP, queries the IP intelligence API, stores the response, and combines it with sender, authentication, URL, and AI signals.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

46. URL

Concept

A Uniform Resource Locator identifies a web resource.

For email security, the displayed link text and actual destination can differ. URL analysis should inspect the real destination, hostname, protocol, path, redirects where available, and other risk indicators.

Practical example

Example: the visible text says 'Open your account' while the underlying destination points to an unrelated domain.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

47. Domain Name

Concept

A domain name provides a human-readable identity for Internet services.

In phishing analysis, the important question is whether the registrable domain belongs to the expected organization. Subdomains can be misleading if users focus only on the first familiar word.

Practical example

Example: login.example-attacker.com is controlled by example-attacker.com, not necessarily by example.com.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

48. Subdomain

Concept

A subdomain is a label placed before a parent domain.

Attackers can use familiar words such as 'login', 'secure', or 'support' in a subdomain to create visual trust. The registrable domain should be checked carefully.

Practical example

Example: `secure-bank.example-attacker.com` may look trustworthy at a glance but is controlled by `example-attacker.com`.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

49. HTTPS

Concept

HTTPS encrypts traffic between a client and a web server and helps authenticate the server through certificates.

HTTPS does not mean the website itself is legitimate. Phishing sites can use valid HTTPS certificates.

Practical example

Example: a fraudulent login page can display a padlock and still steal credentials.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

50. URL Shorteners

Concept

URL shorteners hide the final destination behind a short link.

They are used legitimately, but they reduce transparency during security review. Unexpected shortened links deserve additional verification.

Practical example

Example: a message asks the user to click a shortened URL to review an invoice. The user should verify the request before opening it.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

51. URL Redirects

Concept

A redirect sends a browser from one URL to another.

Attackers may use redirect chains to conceal the final destination or to deliver different content to different visitors. A security system can record redirect information when its scanning method supports it.

Practical example

Example: an email link points to a benign-looking redirector and ultimately reaches a credential-harvesting page.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

52. Punycode and Homograph Domains

Concept

Internationalized domain names can be represented using ASCII-compatible encoding such as punycode.

Visually similar characters from different writing systems can also create deceptive domain names. Applications should rely on safe URL parsing and clear domain display rather than visual similarity alone.

Practical example

Example: a domain may visually resemble a trusted brand while using a different character set.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

53. Malicious URL Scanner

Concept

A malicious URL scanner evaluates a URL using threat-intelligence and security signals.

In a platform such as this, the URL result can be combined with AI analysis and sender context. A scanner verdict should be stored with its provider and timestamp because threat intelligence changes over time.

Practical example

Example: a suspicious link is sent to the URL intelligence service and returned as risky; the system increases the email's overall risk rather than treating the URL result as the only evidence.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

54. DNS

Concept

Domain Name System translates domain names into network records.

Security analysis can examine DNS information such as addresses and mail-related records. DNS changes over time, so historical analysis should record when the information was observed.

Practical example

Example: a newly registered domain resolves to an address associated with suspicious infrastructure.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

55. MX Records

Concept

Mail exchanger, or MX, records indicate which servers receive email for a domain.

They can help explain a domain's mail infrastructure. MX records alone do not prove that a domain is trustworthy.

Practical example

Example: a company domain uses a known cloud mail provider, while a suspicious look-alike domain uses unrelated hosting.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

56. Domain Age

Concept

Domain age is sometimes used as a risk signal.

Newly created domains are common in some phishing campaigns, but new legitimate businesses also create new domains. Domain age should therefore be treated as supporting evidence rather than a verdict.

Practical example

Example: a login domain was registered recently and is also linked from an unsolicited credential request. The combination is more concerning.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

57. Attachments

Concept

Email attachments can contain documents, archives, scripts, executables, or other content.

Unexpected files should be treated cautiously because attackers can use attachments for malware delivery, credential theft, or social engineering.

Practical example

Example: an unexpected invoice arrives as a ZIP archive and asks the user to enable content. This combination is suspicious.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

58. PDF Safety

Concept

PDF files are common business documents but are not automatically safe.

A PDF can contain links, embedded content, or exploit opportunities depending on software and configuration. Users should verify unexpected PDFs before opening them.

Practical example

Example: an unsolicited 'invoice' PDF contains a button that redirects to a login page.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

59. Office Documents

Concept

Word and Excel documents can contain active content such as macros.

Modern Office protections reduce some risks, but users should not enable content in unexpected documents simply because the document asks them to.

Practical example

Example: an invoice document says 'Enable editing and macros to view the invoice.' That is a strong warning sign.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

60. ZIP and Archive Files

Concept

Archives can hide their contents and may contain executables or scripts.

Attackers may use password-protected archives to make automated inspection harder. Unexpected archives should be verified before opening.

Practical example

Example: a message says a delivery notice is attached as a password-protected ZIP and provides the password in the same email.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

61. Executable Attachments

Concept

Executable files can directly run code on a device.

Unexpected executable attachments should be treated as high risk. File extensions can be misleading, so users should not rely solely on the displayed filename.

Practical example

Example: an attachment named 'invoice.pdf.exe' attempts to look like a PDF while remaining executable.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

62. Attachment Sandboxing

Concept

Sandboxing executes suspicious files in an isolated environment to observe behavior without exposing the production workstation.

It is an advanced security control and should be performed by appropriate security systems, not casually by users.

Practical example

Example: a security platform detonates a document in an isolated environment and observes an unexpected network connection.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

63. Malware

Concept

Malware is malicious software designed to disrupt, damage, spy on, gain unauthorized access to, or otherwise abuse systems.

Email is a common delivery mechanism for malware through attachments, links, or compromised accounts.

Practical example

Example: a fake invoice attachment launches a malicious program that attempts to steal browser credentials.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

64. Ransomware

Concept

Ransomware is malware that can encrypt or otherwise block access to data and may demand payment.

Phishing attachments and compromised credentials are common entry points. Prevention, backups, least privilege, and rapid incident response are important defenses.

Practical example

Example: an employee opens a malicious attachment, and the malware later encrypts files accessible to the account.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

65. Credential Theft

Concept

Credential theft is the unauthorized acquisition of usernames, passwords, tokens, session information, or other authentication material.

Phishing pages often imitate legitimate login portals to capture these secrets.

Practical example

Example: a fake Microsoft login page collects a username and password and then redirects the user to the real service.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

66. MFA

Concept

Multi-factor authentication requires multiple authentication factors, such as a password plus a physical security key, authenticator application, or other approved factor.

MFA reduces the impact of stolen passwords but does not eliminate all account attacks.

Practical example

Example: a stolen password is not sufficient to access an account protected by a properly configured second factor.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

67. MFA Fatigue

Concept

MFA fatigue attacks repeatedly generate authentication prompts hoping the victim approves one accidentally or out of frustration.

Users should deny unexpected prompts and report repeated unsolicited authentication requests.

Practical example

Example: a user receives five sign-in approval prompts without attempting to log in.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

68. Passkeys

Concept

Passkeys are a modern authentication approach based on public-key cryptography and device-backed credentials.

They can reduce exposure to password phishing because the authentication is bound to the legitimate website or service context.

Practical example

Example: a user authenticates with a passkey on the real service without typing a reusable password into a webpage.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

69. OAuth Consent Phishing

Concept

OAuth consent phishing attempts to trick a user into authorizing a malicious application.

The attacker may not need the user's password if the user grants access through a legitimate consent flow.

Practical example

Example: an attacker sends a message asking a user to approve a 'document viewer' application that requests access to mail data.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

70. Session Hijacking

Concept

Session hijacking involves unauthorized use of a valid authenticated session or session token.

It can allow access even when the attacker does not know the user's password. Session security, device protection, and timely revocation are important.

Practical example

Example: a stolen session token is used to access an already authenticated service.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

71. Account Compromise

Concept

An account is compromised when an unauthorized party gains access or control.

Indicators can include unfamiliar sign-ins, sent messages the user did not create, changed recovery information, suspicious forwarding rules, and unexpected MFA prompts.

Practical example

Example: the user notices password-reset messages and sent emails that they never wrote.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

72. Account Recovery

Concept

After suspected compromise, users should use the legitimate service's recovery and security controls.

Typical actions include changing the password, reviewing active sessions, checking recovery methods, confirming MFA, removing suspicious application access, and reporting the incident.

Practical example

Example: after entering a password into a phishing page, the user changes the password from the real service and reviews all active sessions.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

73. Mail Forwarding Rules

Concept

Attackers who compromise mail accounts may create forwarding or filtering rules to hide or exfiltrate messages.

Users and administrators should review unfamiliar rules during account-compromise investigations.

Practical example

Example: messages containing 'invoice' are silently forwarded to an external mailbox.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

74. Spam

Concept

Spam is unwanted or unsolicited messaging.

Spam is not always malicious, and malicious messages are not always classified as spam. Security systems should distinguish user inconvenience from security risk.

Practical example

Example: a marketing email can be unwanted but legitimate, while a targeted phishing email may appear in the Inbox.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

75. Phishing vs Spam

Concept

Spam describes unwanted bulk communication, while phishing describes deceptive attempts to obtain information or cause an unsafe action.

The categories can overlap, but they are not synonyms.

Practical example

Example: a newsletter may be spam-like for a recipient but is not phishing if it does not attempt deception or theft.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

76. Social Engineering

Concept

Social engineering exploits human decision-making.

Common psychological triggers include urgency, authority, fear, curiosity, scarcity, reward, and familiarity. Security awareness helps users recognize these patterns before acting.

Practical example

Example: 'Your account will be closed in 10 minutes' uses urgency to discourage independent verification.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

77. Urgency

Concept

Urgency is a common phishing signal because it creates pressure and reduces time for verification.

Legitimate urgent requests can exist, so urgency should trigger verification rather than an automatic rejection.

Practical example

Example: an email requests immediate payment within one hour and says no questions should be asked.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

78. Authority Impersonation

Concept

Attackers may impersonate managers, banks, government agencies, IT teams, or vendors.

Authority can make victims follow instructions without normal verification.

Practical example

Example: a fake IT message asks the employee to provide an MFA code to 'complete a security check.'

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

79. Fear and Threats

Concept

Fear-based messages claim that an account, payment, legal status, or service will be harmed unless the recipient acts immediately.

Users should independently verify such claims rather than responding under pressure.

Practical example

Example: 'Failure to pay today will result in account suspension' is a classic pressure pattern.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

80. Reward Scams

Concept

Reward or prize scams promise money, gifts, refunds, or exclusive benefits to motivate users to click or provide information.

Unexpected rewards should be treated cautiously.

Practical example

Example: a message says the recipient has won a prize but must pay a small processing fee first.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

81. QR Phishing

Concept

QR phishing uses QR codes to direct users to websites or workflows.

QR codes can hide the destination from casual inspection. Users should verify the destination and request context before entering credentials or payment information.

Practical example

Example: an email contains a QR code labeled 'Secure your account' that opens an unrelated domain.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

82. Smishing

Concept

Smishing is phishing delivered through SMS or text messages.

It often uses delivery notifications, account alerts, financial warnings, or urgent links. The same verification principles used for email apply.

Practical example

Example: a text says a package is waiting and requests a small payment through a link.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

83. Vishing

Concept

Vishing is voice-based phishing.

Attackers may claim to be bank employees, technical support, government officials, or coworkers. Never provide secrets merely because a caller sounds convincing.

Practical example

Example: a caller asks for an OTP to 'verify your identity.'

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

84. Invoice Fraud

Concept

Invoice fraud manipulates payment processes.

Attackers may send fake invoices, alter payment details, or impersonate vendors. Independent verification of payment changes is one of the strongest defenses.

Practical example

Example: a supplier's bank account suddenly changes, and the email says the change must be used immediately.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

85. Payroll Diversion

Concept

Payroll diversion attempts to redirect an employee's salary or payment to an attacker-controlled account.

Requests to change payroll information should use an approved verification process.

Practical example

Example: an attacker impersonates an employee and asks HR to update the bank account.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

86. Gift Card Scam

Concept

Gift-card scams often impersonate executives and request urgent purchases.

They exploit authority and speed. Organizations should define clear rules that executives cannot bypass normal approval processes through email.

Practical example

Example: a fake manager asks an employee to buy several gift cards and send the codes.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

87. Vendor Impersonation

Concept

Vendor impersonation occurs when attackers imitate a supplier or service provider.

The attacker may use similar branding, a compromised account, or a look-alike domain.

Practical example

Example: a supplier-like email sends a new bank account and asks finance to update the vendor record.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

88. BEC Verification

Concept

Payment, bank-detail, payroll, or sensitive-data requests should be independently verified.

The verification channel should not rely on contact details contained in the suspicious email.

Practical example

Example: instead of replying to the email, finance calls the vendor using a phone number already stored in the vendor master record.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

89. False Positive

Concept

A false positive occurs when a security system flags a benign message as suspicious.

False positives are expected in detection systems and should be managed through evidence, feedback, thresholds, and review.

Practical example

Example: a legitimate marketing link is flagged because its domain has characteristics associated with tracking services.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

90. False Negative

Concept

A false negative occurs when a malicious message is not detected.

No detector is perfect, especially when attackers use compromised legitimate accounts or newly created infrastructure.

Practical example

Example: a compromised supplier mailbox sends a realistic invoice that passes normal authentication checks.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

91. Risk Score

Concept

A risk score summarizes multiple signals into a user-facing assessment.

The score should be accompanied by reasons so the user understands what influenced it. Scores from different providers should not be assumed to be directly comparable.

Practical example

Example: high risk may be caused by a suspicious URL, sender mismatch, authentication failure, and an urgent credential request.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

92. Risk Levels

Concept

A practical interface can group risk into categories such as Low, Medium, High, and Critical.

The exact thresholds should be defined by the application's detection policy and validated against test data. The labels should communicate recommended actions.

Practical example

Example: Medium means verify before acting; High means avoid interaction and report; Critical means treat the message as an urgent security event.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

93. Evidence vs Conclusion

Concept

Security analysis should separate observations from conclusions. 'SPF failed' is an observation.

'The attacker is spoofing the domain' is an interpretation that may be supported by that observation plus other evidence. This distinction reduces overclaiming.

Practical example

Example: the dashboard can show 'Observed: DMARC failed' and separately 'Assessment: sender identity is suspicious.'

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

94. AI Email Analysis

Concept

AI can classify message intent, summarize content, identify social-engineering patterns, explain suspicious indicators, and combine contextual signals.

AI should support security analysis rather than pretending to provide certainty.

Practical example

Example: the AI explains that an email combines urgency, credential requests, and a domain mismatch.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

95. Explainable AI

Concept

Explainable analysis shows the main reasons behind a classification.

For a user, explanations should be simple and actionable. Technical evidence can be expanded for investigators.

Practical example

Example: 'High risk because the sender domain differs from the expected company domain and the message asks for your password.'

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

96. AI Hallucination

Concept

AI systems can generate unsupported statements.

A security assistant should ground explanations in retrieved knowledge and actual email evidence. It should avoid inventing IP ownership, sender identity, or source references.

Practical example

Example: if no evidence identifies a person, the assistant should say it cannot identify the person rather than guessing.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

97. RAG

Concept

Retrieval-Augmented Generation combines retrieval of relevant knowledge with language generation.

For this project, trusted user-security documents can explain concepts while user-specific email evidence can explain why a particular message was flagged. The two layers should remain logically separated.

Practical example

Example: the assistant retrieves a phishing explanation from the trusted knowledge base and retrieves the user's analyzed email evidence to explain the specific warning.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

98. Trusted RAG Knowledge

Concept

The global RAG knowledge base should contain curated cybersecurity guidance and educational material.

Documents should have source, title, date, topic, and page metadata where possible. Retrieval should prefer relevant authoritative material.

Practical example

Example: a user asks what DMARC means and the system retrieves the DMARC section from trusted security documentation.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

99. User Email Evidence RAG

Concept

Analyzed emails can be transformed into normalized evidence records and embedded for retrieval.

These records must be scoped to the authenticated user. This lets the assistant answer questions about the user's own emails without mixing one user's data into another user's evidence.

Practical example

Example: the user asks 'Why was yesterday's invoice email risky?' and retrieval finds that user's stored evidence for that email.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

100. User Isolation

Concept

Email evidence is private data.

Backend retrieval must always enforce authorization using the authenticated identity and server-side filters. A frontend-provided user ID must never be trusted as the security boundary.

Practical example

Example: a user cannot query another user's email evidence merely by changing a `user_id` parameter in a browser request.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

101. RAG Chunking

Concept

Chunking divides documents into retrieval units.

Chunks should preserve enough context to answer questions while remaining focused. Topic boundaries, headings, and page metadata can improve retrieval quality.

Practical example

Example: a DMARC chunk should explain the concept and interpretation rather than splitting the definition from its key limitation.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

102. Embeddings

Concept

Embeddings represent text as numerical vectors so semantically related content can be retrieved.

The same embedding model and compatible vector dimensions should be used consistently for indexing and retrieval.

Practical example

Example: a query about 'Why did the sender fail authentication?' can retrieve content about SPF, DKIM, DMARC, and Authentication-Results even if the wording differs.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

103. Vector Search

Concept

Vector search retrieves content based on semantic similarity.

Metadata filters should be used with vector search to enforce namespaces and authorization. For user evidence, `user_id` and email identifiers are important filters.

Practical example

Example: a user query searches the user knowledge namespace plus that authenticated user's email evidence namespace.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

104. Supabase pgvector

Concept

A PostgreSQL database with pgvector can store embeddings alongside document metadata and support vector similarity search.

For this project, Supabase can store users, email analysis results, RAG documents, chunks, and user-specific email evidence.

Practical example

Example: rag_chunks stores trusted knowledge while email_evidence_chunks stores normalized evidence scoped to a user.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

105. Threat Intelligence Correlation

Concept

Threat intelligence becomes more useful when multiple observations are correlated.

Sender domain, URL, IP, authentication results, message content, and historical indicators can reinforce or contradict each other.

Practical example

Example: a suspicious URL and a recently observed abusive IP strengthen the case when both are connected to the same email.

How the user should interpret it

Treat this information as a security signal and combine it with the message context. Do not use a single technical field to identify a person or declare an email malicious with absolute certainty. For high-impact requests, independently verify the request using a trusted channel.

Recommended authoritative source families

- NIST cybersecurity publications and guidance
- CISA phishing, incident response, and cybersecurity awareness guidance
- FBI Internet Crime Complaint Center reports and fraud guidance
- MITRE ATT&CK; technique documentation
- Microsoft security and email-authentication guidance
- ENISA threat landscape and cybersecurity guidance
- NSA and partner cybersecurity guidance where relevant

RAG metadata recommendations

- document_id
- document_name
- source
- organization
- publication_year
- page_number
- rag_type
- chunk_index
- topic
- created_at

Email evidence metadata recommendations

- user_id
- email_id
- gmail_message_id
- sender
- subject
- labels
- threat_category
- risk_score
- risk_level
- urls
- ips
- authentication_results
- ai_summary
- recommended_action

User-facing answer policy

- Explain technical terms in simple language.
- Separate observed evidence from interpretation.
- State limitations for geolocation, reputation, AI, and authentication.
- Do not identify a person from an IP address.
- Do not reveal another user's email evidence.
- For sensitive actions, recommend independent verification.

Core distinction table

- SPF = sending-server authorization signal.
- DKIM = cryptographic signature verification.
- DMARC = policy plus authentication/alignment for the visible From domain.
- VPN = alternate network endpoint/tunnel; legitimate and not proof of attack.
- Proxy = intermediary; can obscure original source.
- TOR = multi-relay privacy network; observed exit IP is not the original source.
- IP geolocation = approximate database location of observed network infrastructure, not exact person location.
- IP reputation = provider-specific risk signal, not a verdict.